



الجامعة اللبنانية
UNIVERSITE LIBANAISE

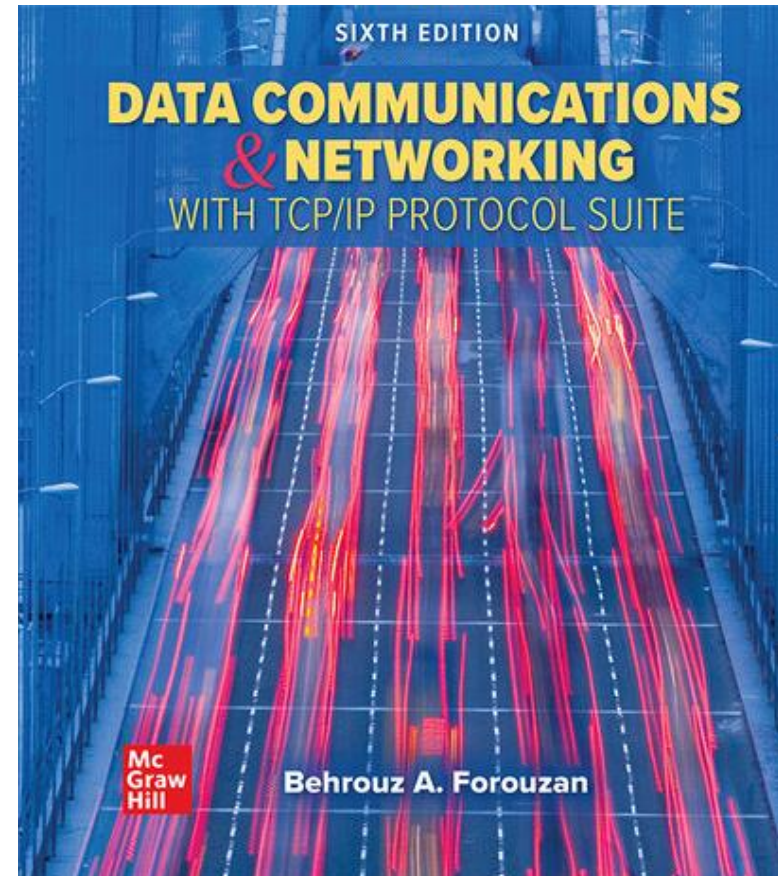
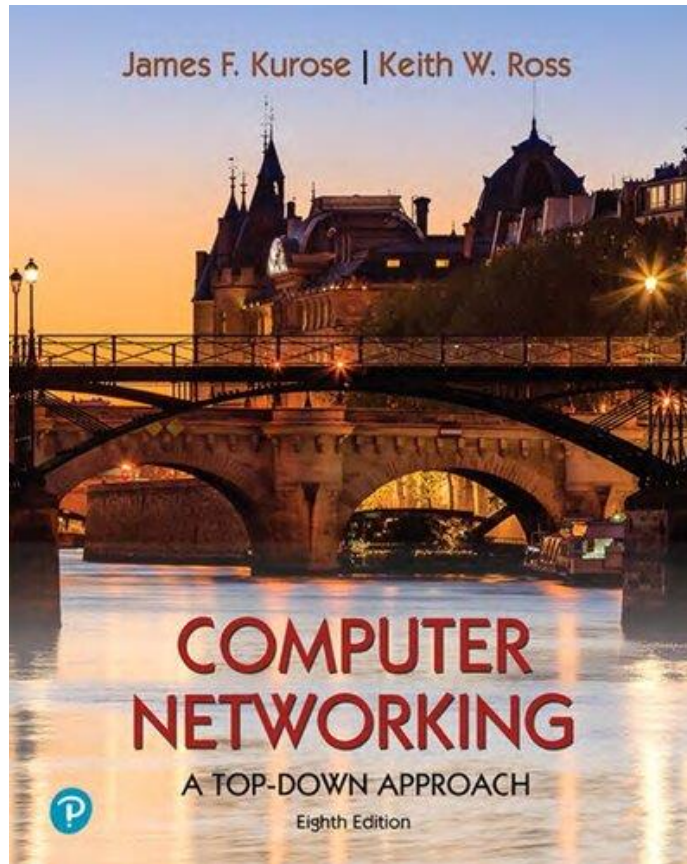


I3304

Network administration and security

Ahmad Fadlallah

Reference Textbooks





Outline

- Introduction
 - ⊙ Introduction to the course
 - ⊙ Recall Network Basics (I2208)
- Network Layer
 - ⊙ Static Routing
 - ⊙ Dynamic Routing
 - Dynamic Routing Algorithm
 - Dynamic Routing Protocols
 - ⊙ NAT (Network Address Translation)
 - ⊙ IPv6
- Transport Layer
 - ⊙ Function of the transport layer
 - ⊙ UDP Protocol
 - ⊙ TCP Protocol
 - Connection management
 - Flow control
 - Congestion control
- Application Layer
 - HTTP protocol
 - FTP protocol
 - Telnet
 - Mail protocols
 - DNS
 - P2P Applications
- Introduction to Security
 - Security services
 - Cryptography
 - Digital Signature
 - Principle of network security protocols

References



- The slides are based on the:
 - ◉ Jim Kurose, Keith Ross Slides for the Computer Networking: A Top-Down Approach, 8th edition, Pearson, 2020
 - ◉ Cisco Networking Academy Program, Routing and Switching Essentials v6.0



Introduction to Security: Outline

- Security services
- Cryptography
- Digital Signature
- Principle of network security protocols

Definitions



- **Computer Security:** generic name for the collection of tools designed to protect data and to thwart hackers
- **Network Security :** measures to protect data during their transmission
- **Internet Security/ Cybersecurity:** measures to protect data during their transmission over a collection of interconnected networks i.e., in the cyberspace
- **Information Security:** involves the protection of data across all mediums

OSI Security Architecture



- ITU-T X.800 “Security Architecture for OSI”
- Defines a systematic way of defining and providing security requirements
- for us it provides a useful, if abstract, overview of concepts we will study

Aspects of Security



- 3 aspects of information security:

- ⊙ **security attacks (and threats)**

- actions that (may) compromise security

- ⊙ **security services**

- services counter to attacks

- ⊙ **security mechanisms**

- used by services
 - E.g., secrecy is a service, encryption (a.k.a. encipherment) is a mechanism

Security Attack

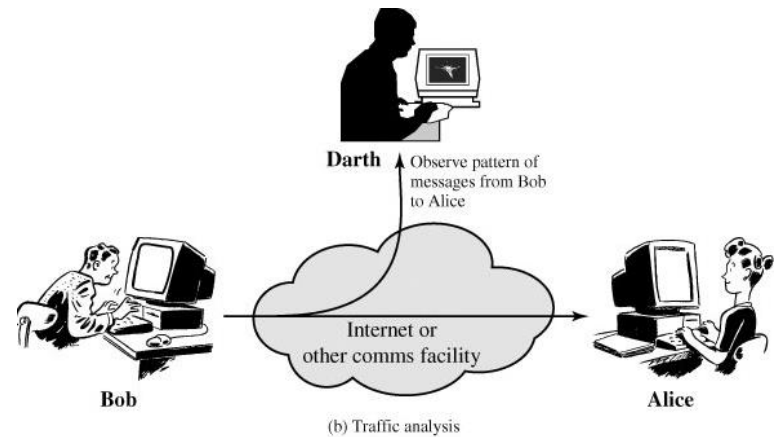
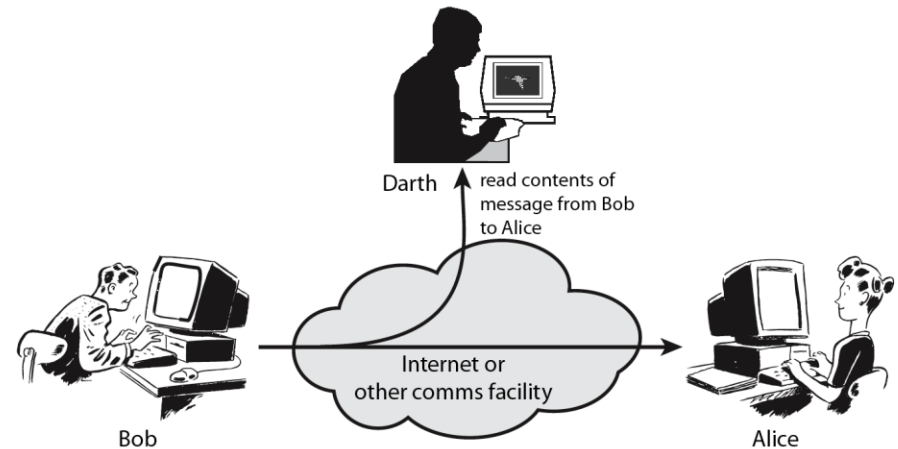


- Any action that compromises the security of information owned by an organization
- Information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
- Often threat & attack used to mean same thing But, there is a difference...
- have a wide range of attacks
- can focus of generic types of attacks
 - ⊙ passive
 - ⊙ active

Passive Attacks



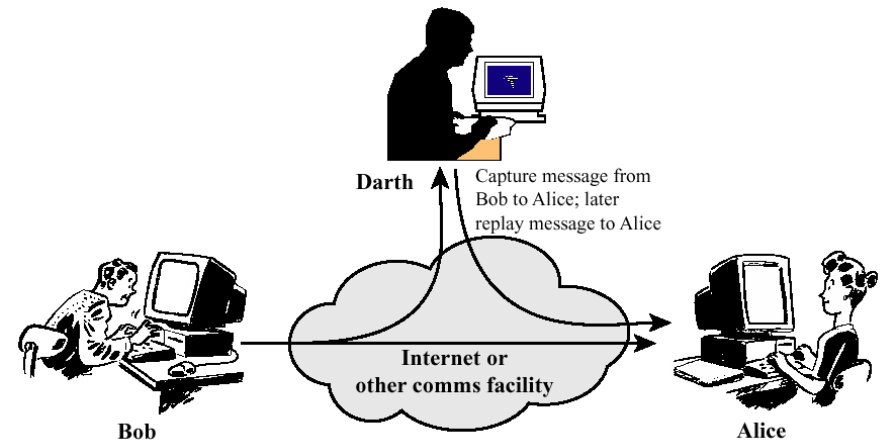
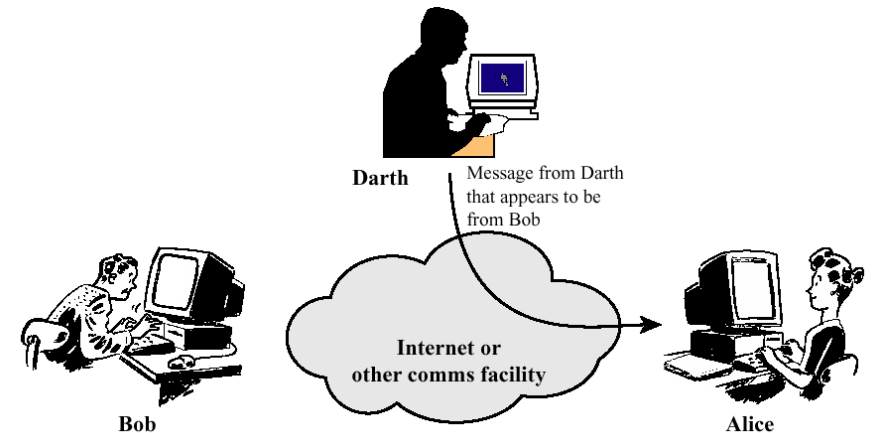
- interception of the messages
- What can the attacker do?
 - ◉ read the content
 - ◉ traffic analysis
 - hard to avoid
- Hard to detect, try to prevent



Active attacks



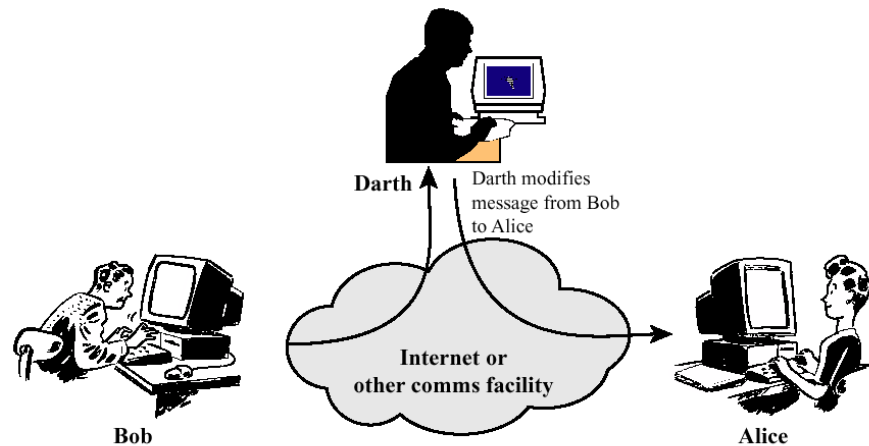
- Attacker actively manipulates the communication
- Masquerade
 - ⊙ pretend as someone else
 - ⊙ possible to get more privileges
- Fabrication
 - ⊙ create a bogus message
- Replay
 - ⊙ passively capture data and send later
- Denial-of-service
 - ⊙ prevention the normal use of servers, end users, or network itself





Active attacks

- deny
 - ⊙ repudiate sending/receiving a message later
- modification
 - ⊙ change the content of a message



Security Service



- Enhance security of data processing systems and information transfers of an organization
- Intended to counter security attacks
- Using one or more security mechanisms
- Often replicates functions normally associated with physical documents
 - ◉ which, for example, have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed
- X.800:
 - “a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers”
- RFC 2828:
 - “a processing or communication service provided by a system to give a specific kind of protection to system resources”



Basic Security Services

- **Authentication**

- ⊙ assurance that the communicating entity is the one it claims to be
- ⊙ peer entity authentication
 - mutual confidence in the identities of the parties involved in a connection
- ⊙ Data-origin authentication
 - assurance about the source of the received data

- **Access Control**

- ⊙ prevention of the unauthorized use of a resource

Basic Security Services



- **Data Confidentiality**

- ◉ protection of data from unauthorized disclosure (against eavesdropping)
- ◉ traffic flow confidentiality is one step ahead

- **Data Integrity**

- ◉ assurance that data received are exactly as sent by an authorized sender
- ◉ i.e. no modification, insertion, deletion, or replay



Basic Security Services

- **Non-Repudiation**

- ⊙ protection against denial by one of the parties in a communication

- ⊙ Origin non-repudiation

- proof that the message was sent by the specified party

- ⊙ Destination non-repudiation

- proof that the message was received by the specified party

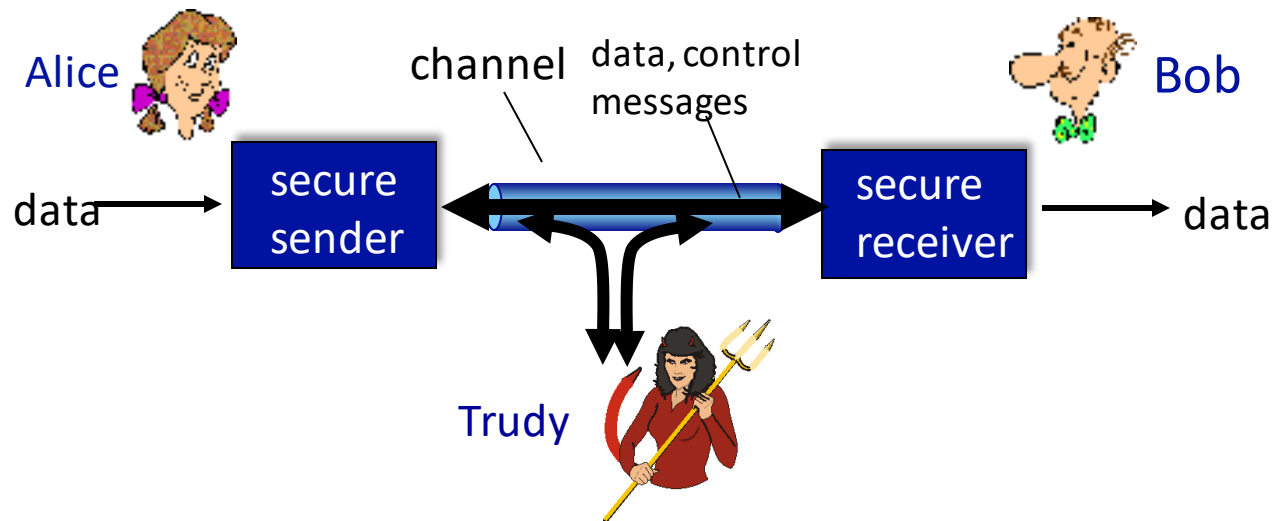
- **Availability**

- ⊙ The property of a system or a system resource being accessible and usable upon demand by an authorized system entity



Friends and enemies: Alice, Bob, Trudy

- well-known in network security world
- Bob, Alice want to communicate “securely”
- Trudy (intruder) may intercept, delete, add messages



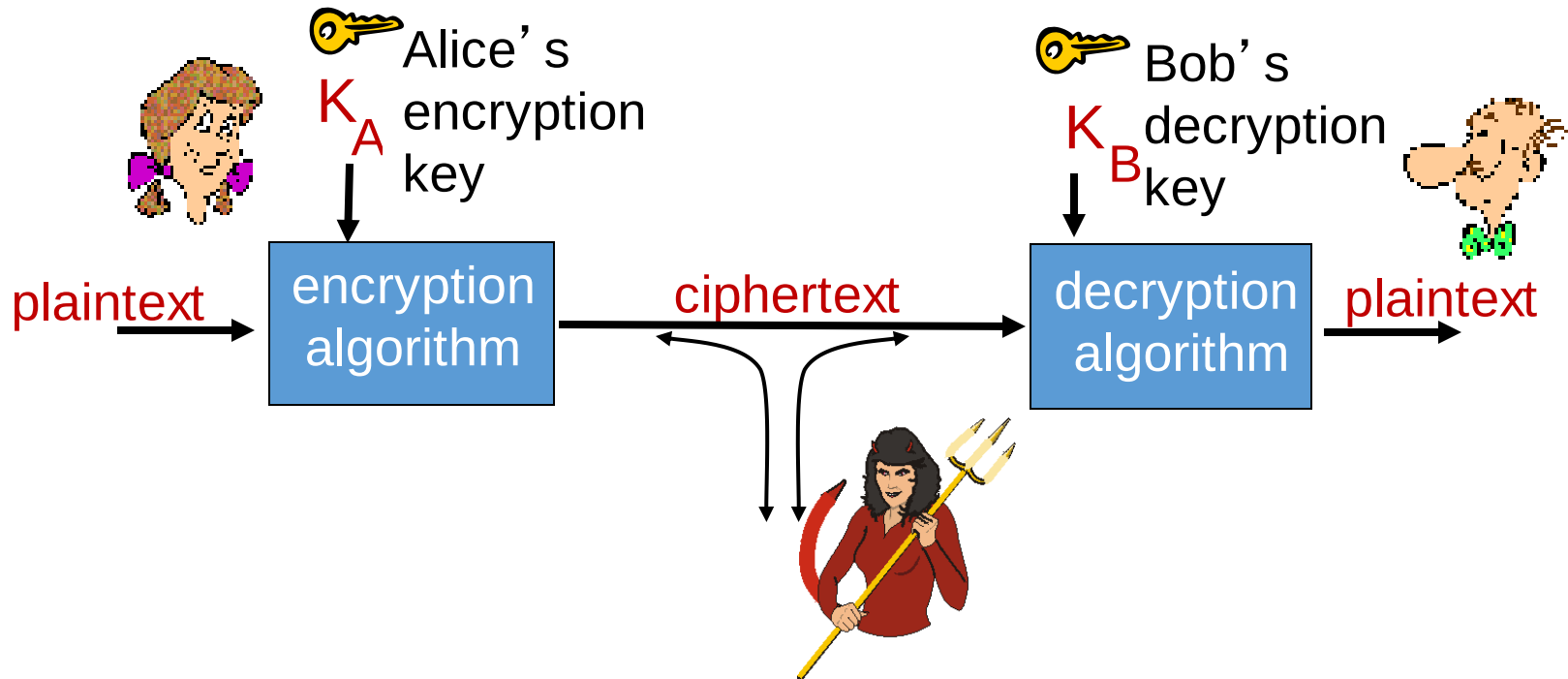


Friends and enemies: Alice, Bob, Trudy

Who might Bob and Alice be?

- ... well, *real-life* Bobs and Alices!
- Web browser/server for electronic transactions (e.g., on-line purchases)
- on-line banking client/server
- DNS servers
- BGP routers exchanging routing table updates
- other examples?

The language of cryptography

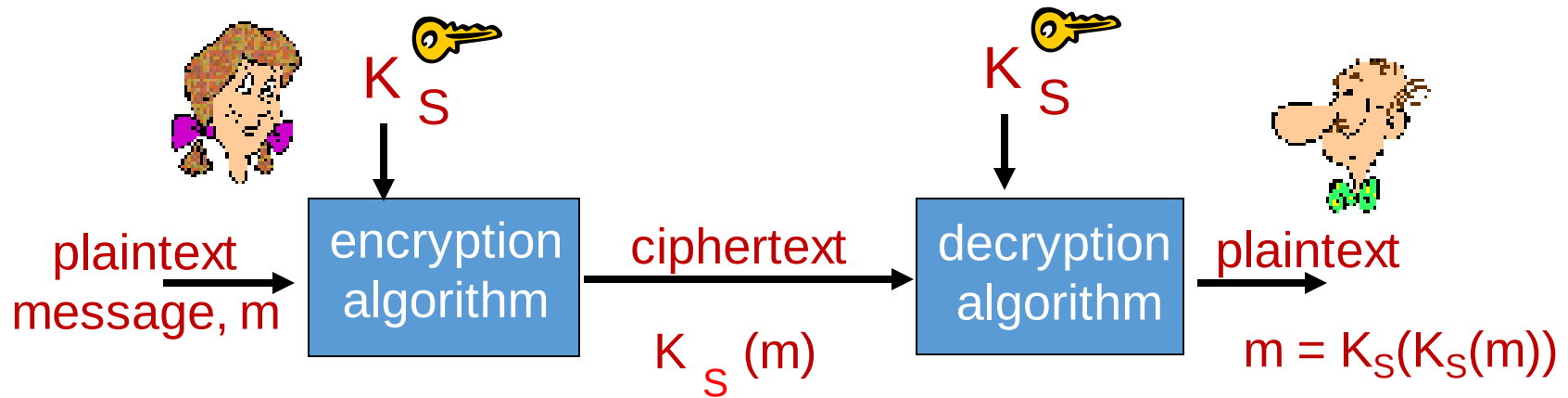


m plaintext message

$K_A(m)$ ciphertext, encrypted with key K_A

$m = K_B(K_A(m))$

Symmetric key cryptography



symmetric key crypto: Bob and Alice share same (symmetric) key: K_S

- e.g., key is knowing substitution pattern in mono alphabetic substitution cipher

Q: how do Bob and Alice agree on key value?



- monoalphabetic cipher: substitute one letter for another

e.g.: Plaintext: bob. i love you. alice
ciphertext: nkn. s gktc wky. mgsbc

🔑 **Encryption key:** mapping from set of 26 letters to set of 26 letters

Symmetric key crypto: DES



DES: Data Encryption Standard

- US encryption standard [NIST 1993]
- 56-bit symmetric key, 64-bit plaintext input
- block cipher with cipher block chaining
- how secure is DES?
- making DES more secure:
 - ◉ 3DES: encrypt 3 times with 3 different keys

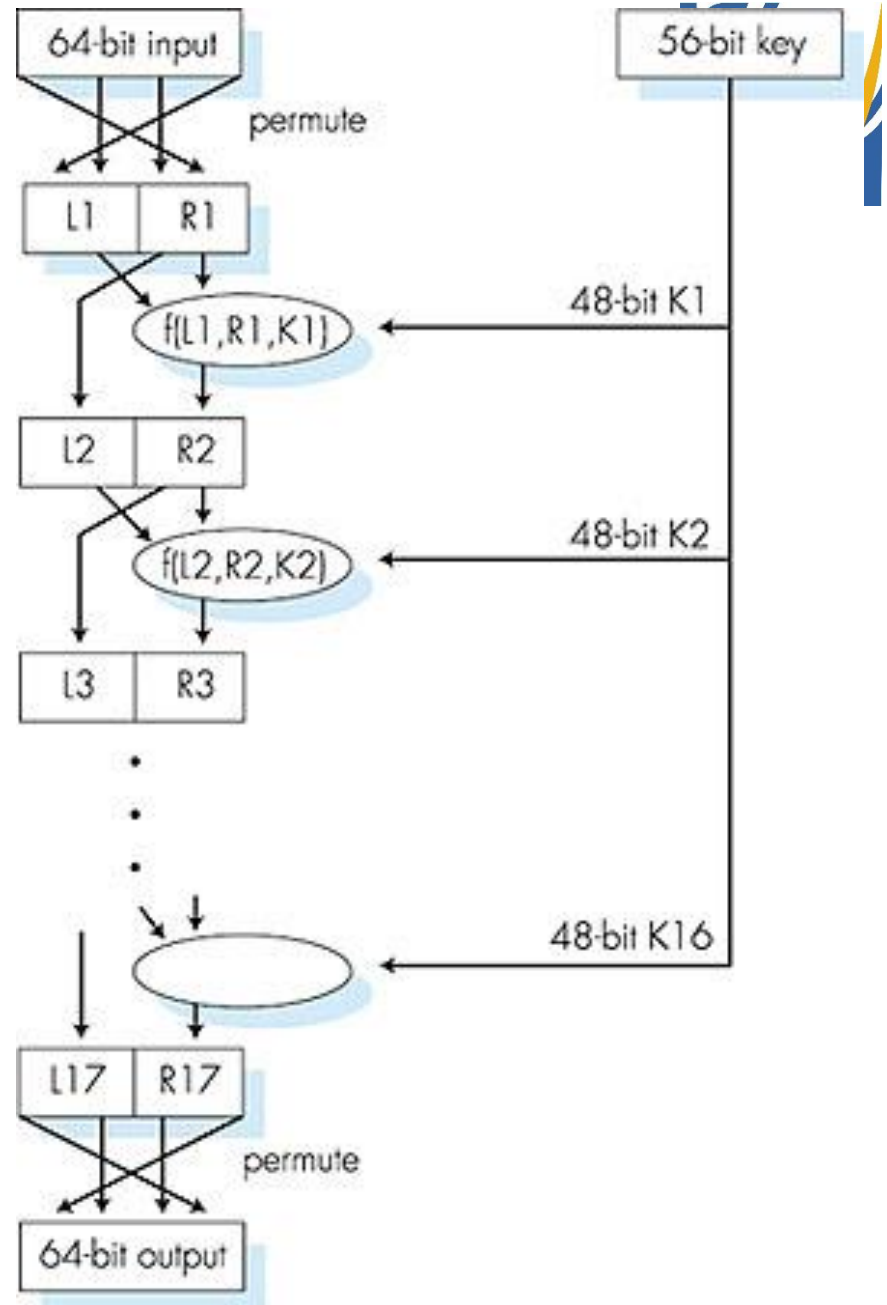
Symmetric key crypto: DES

DES operation

initial permutation

16 identical “rounds” of
function application, each
using different 48 bits of
key

final permutation



AES: Advanced Encryption Standard



- symmetric-key NIST standard, replaced DES (Nov 2001)
- processes data in 128 bit blocks
- 128, 192, or 256 bit keys
- brute force decryption (try each key) taking less than 1 sec on DES, takes 149 trillion years for AES

Public Key Cryptography



symmetric key crypto

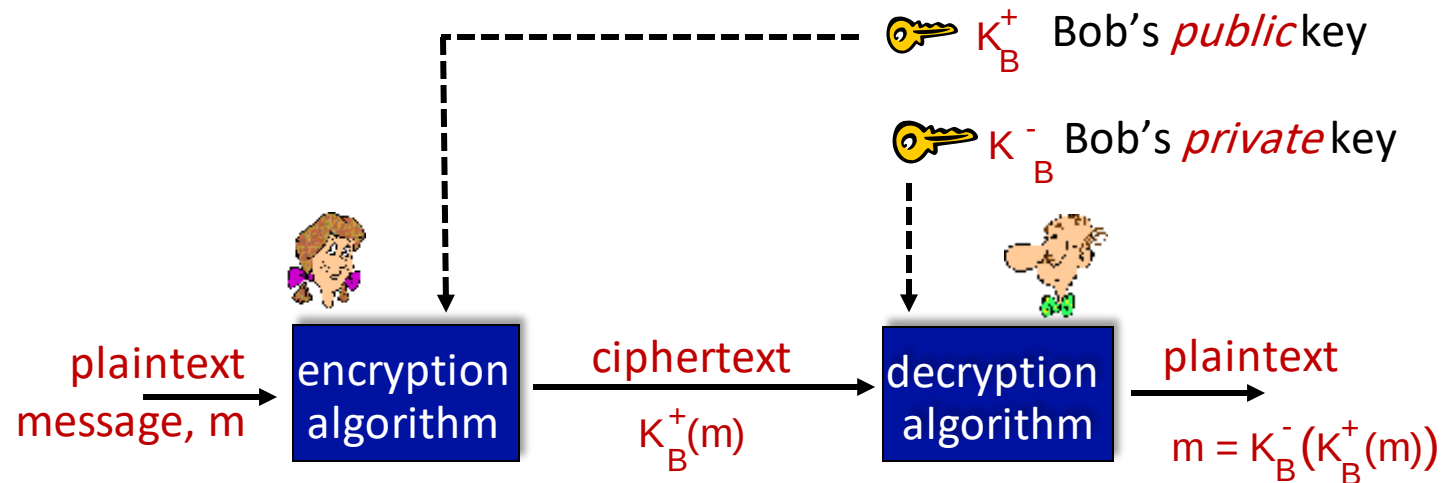
- requires sender, receiver know shared secret key
- Q: how to agree on key in first place (particularly if never “met”)?

public key crypto

- radically different approach [Diffie-Hellman76, RSA78]
- sender, receiver do *not* share secret key
- *public* encryption key known to *all*
- *private* decryption key known only to receiver



Public Key Cryptography



Wow - public key cryptography revolutionized 2000-year-old (previously only symmetric key) cryptography!

- similar ideas emerged at roughly same time, independently in US and UK (classified)

Public key encryption algorithms



requirements:

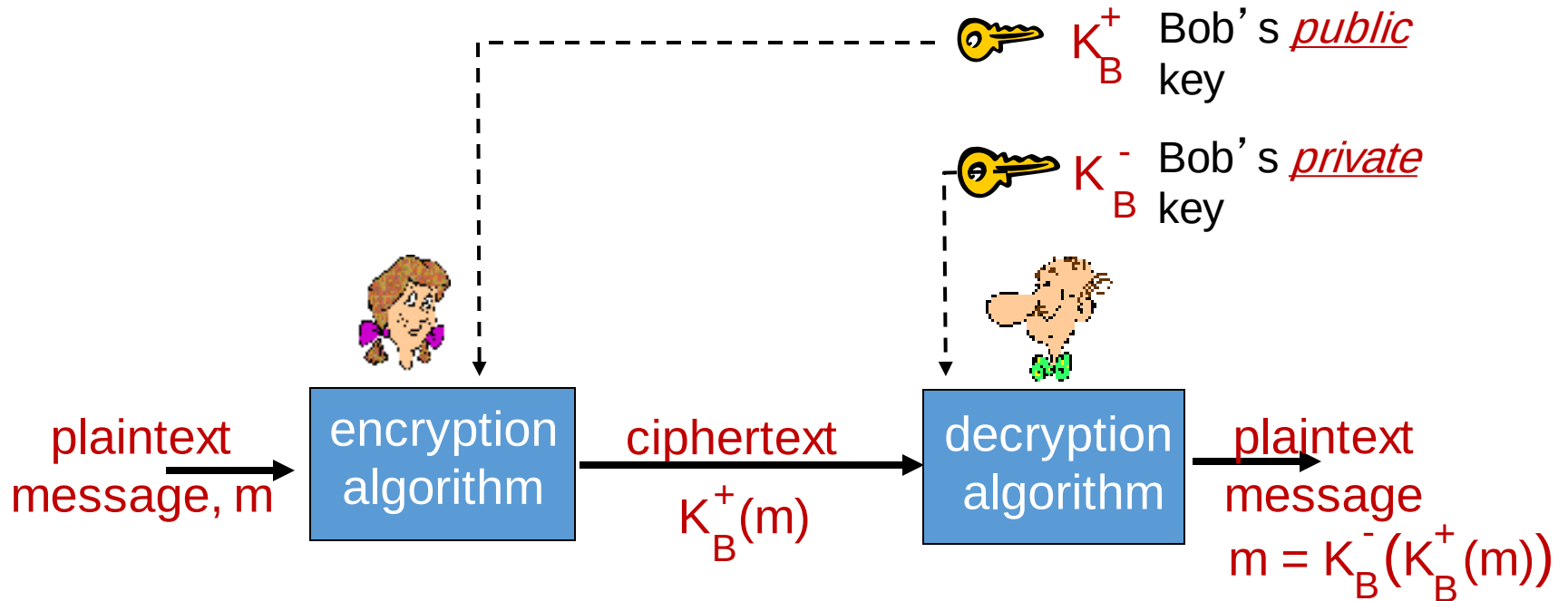
① need $K_B^+(\cdot)$ and $K_B^-(\cdot)$ such that

$$K_B^-(K_B^+(m)) = m$$

② given public key K_B^+ , it should be impossible to compute private key K_B^-

RSA: Rivest, Shamir, Adelson algorithm

Public key cryptography

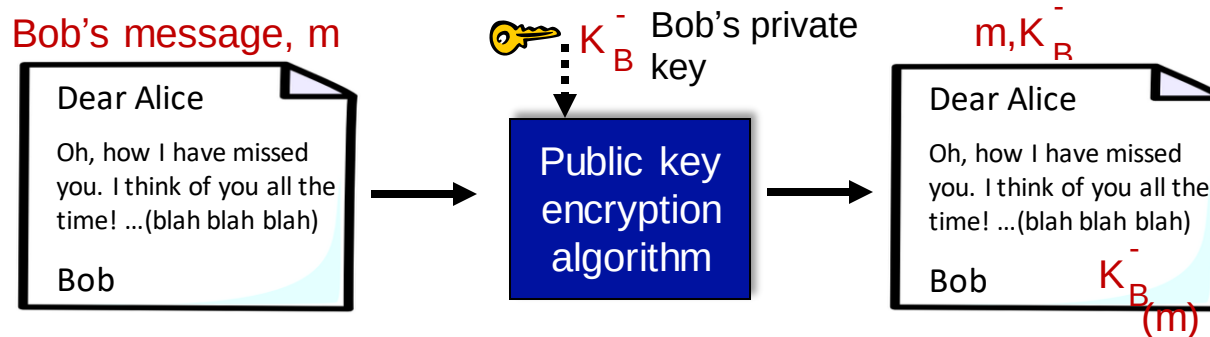


Digital signatures



cryptographic technique analogous to hand-written signatures:

- sender (Bob) digitally signs document: he is document owner/creator.
- *verifiable, nonforgeable*: recipient (Alice) can prove to someone that Bob, and no one else (including Alice), must have signed document
- simple digital signature for message m :
 - Bob signs m by encrypting with his private key K_B , creating “signed” message, $K_B^-(m)$





Digital signatures

- suppose Alice receives msg m , with signature: $m, \bar{K}_B(m)$
- Alice verifies m signed by Bob by applying Bob's public key ^+K_B to $\bar{K}_B(m)$ then checks $^+K_B(\bar{K}_B(m)) = m$.
- If $^+K_B(\bar{K}_B(m)) = m$, whoever signed m must have used Bob's private key

Alice thus verifies that:

- Bob signed m
- no one else signed m
- Bob signed m and not m'

non-repudiation:

- ✓ Alice can take m , and signature $\bar{K}_B(m)$ to court and prove that Bob signed m

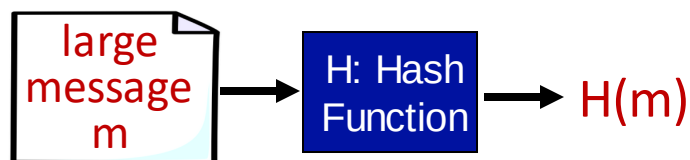


Message digests

computationally expensive to public-key-encrypt long messages

goal: fixed-length, easy- to-compute digital “fingerprint”

- apply hash function H to m , get fixed size message digest, $H(m)$



Hash function properties:

- many-to-1
- produces fixed-size msg digest (fingerprint)
- given message digest x , computationally infeasible to find m such that $x = H(m)$

Internet checksum: poor crypto hash function



Internet checksum has some properties of hash function:

- produces fixed length digest (16-bit sum) of message
- is many-to-one

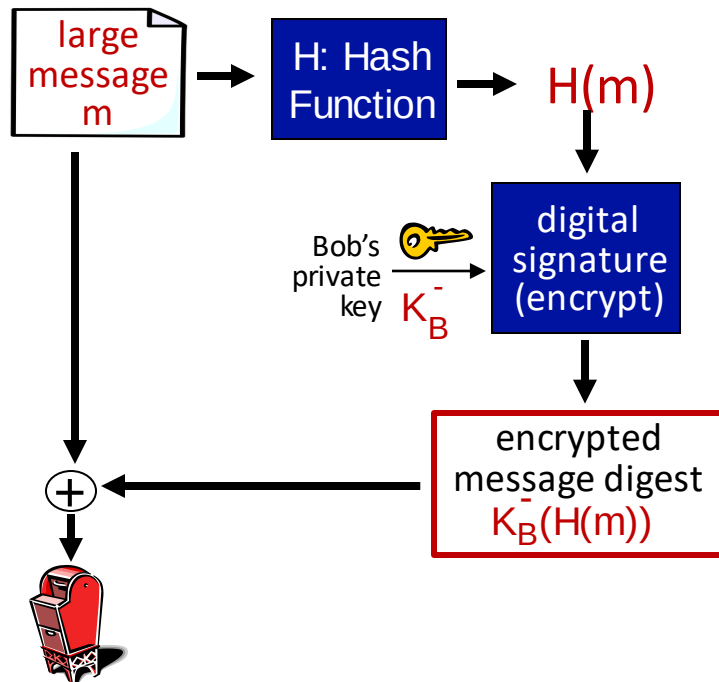
but given message with given hash value, it is easy to find another message with same hash value:

<u>message</u>	<u>ASCII format</u>		<u>message</u>	<u>ASCII format</u>
I O U 1	49 4F 55 31		I O U <u>9</u>	49 4F 55 <u>39</u>
0 0 . 9	30 30 2E 39		0 0 . <u>1</u>	30 30 2E <u>31</u>
9 B O B	39 42 D2 42		9 B O B	39 42 D2 42
B2 C1 D2 AC		 <i>different messages</i> <i>but identical checksums!</i>	B2 C1 D2 AC	

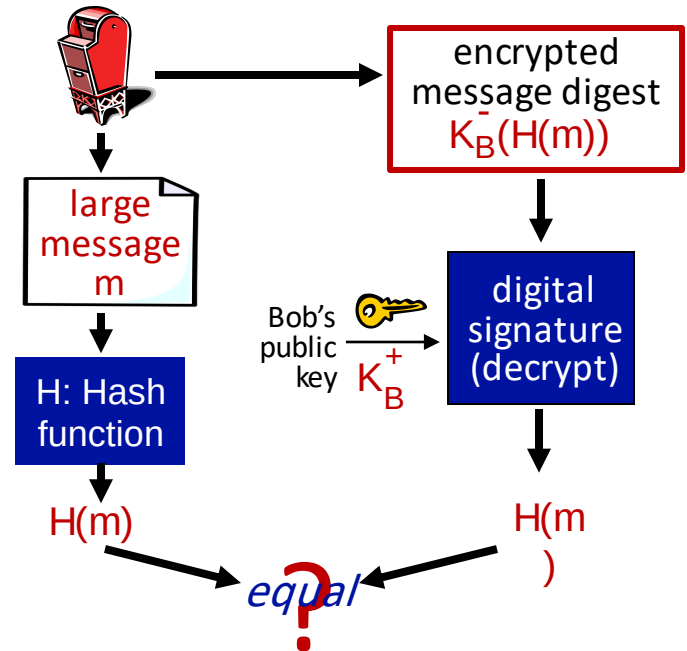
Digital signature = signed message digest



Bob sends digitally signed message:



Alice verifies signature, integrity of digitally signed message:



Hash function algorithms



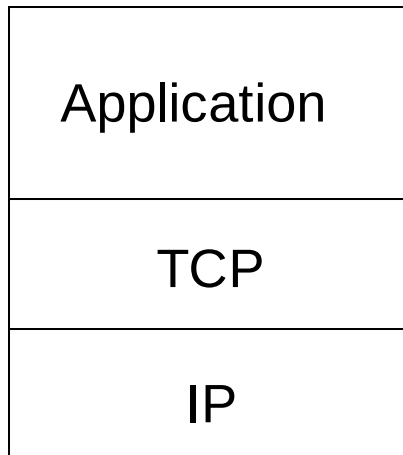
- MD5 hash function widely used (RFC 1321)
 - ⊙ computes 128-bit message digest in 4-step process.
 - ⊙ arbitrary 128-bit string x , appears difficult to construct msg m whose MD5 hash is equal to x
- SHA-1 is also used
 - ⊙ US standard [NIST, FIPS PUB 180-1]
 - ⊙ 160-bit message digest



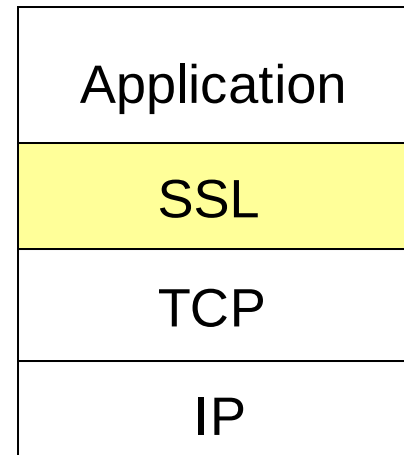
SSL: Secure Sockets Layer

- widely deployed security protocol
 - ⊙ supported by almost all browsers, web servers
 - ⊙ https
 - ⊙ billions \$/year over SSL
- mechanisms: [Woo 1994], implementation: Netscape
- variation -TLS: transport layer security, RFC 2246
- provides
 - ⊙ *confidentiality*
 - ⊙ *integrity*
 - ⊙ *authentication*
- original goals:
 - ⊙ Web e-commerce transactions
 - ⊙ encryption (especially credit-card numbers)
 - ⊙ Web-server authentication
 - ⊙ optional client authentication
 - ⊙ minimum hassle in doing business with new merchant
- available to all TCP applications
 - ⊙ secure socket interface

SSL and TCP/IP



normal application



application with SSL

- SSL provides application programming interface (API) to applications
- C and Java SSL libraries/classes readily available



Toy SSL: a simple secure channel

- **Handshake:** Alice and Bob use their certificates, private keys to authenticate each other and exchange shared secret
- **Key derivation:** Alice and Bob use shared secret to derive set of keys
- **Data transfer:** data to be transferred is broken up into series of records
- **Connection closure:** special messages to securely close connection

Real SSL connection

*everything
henceforth
is encrypted*

TCP FIN follows

